



DEVOIR D'ÉCOLE - 2024

COURS: SÉCURITÉ DES SYSTÈMES DE CONTRÔLE INDUSTRIELS

SUJET: ANALYSE STATIQUE DE MALICIEL ET PDF MALICIEUX — ANALYSE
DE MALWARE DANS CUCKOO SANDBOX — “THREAT DETECTION” AVEC
IOC & RÈGLES YARA — FORENSIQUE AVEC REDLINE

FRÉDÉRIC PERRON



Table des Matières

Exercice 1 – PDF malicieux & Analyse statique de maliciel	1
Exercice 2 – Analyse de maliciel dans une Sandbox (Cuckoo)	6
Exercice 3 – Threat Detection avec IOC & règles YARA	15
Exercice 4 – Analyse forensique avec Redline	21

Consigne

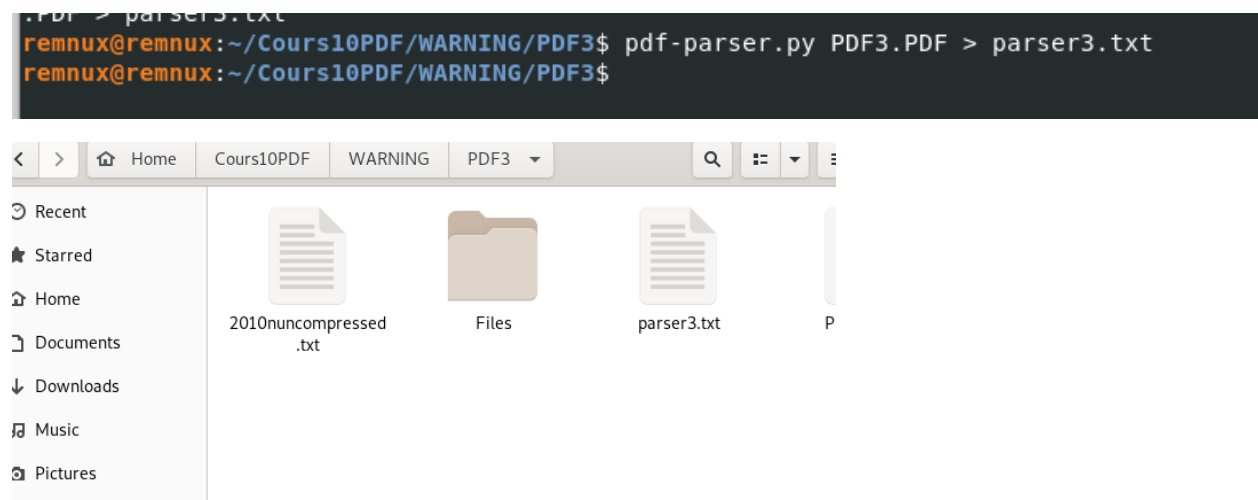
- L'ensemble des réponses doivent être documentées et appuyées de captures d'écran. Même si la réponse est correcte si elle n'est pas documentée votre note sera de **0 point**.
- Vous devez faire preuve d'analyse et de recherche dans les réponses que vous fournissez.
- Veuillez soumettre vos devoirs sous forme de fichiers PDF ou DOC et présenter vos réponses sous les questions ci-dessous en les copiant telles quelles avec leur numéro de question.

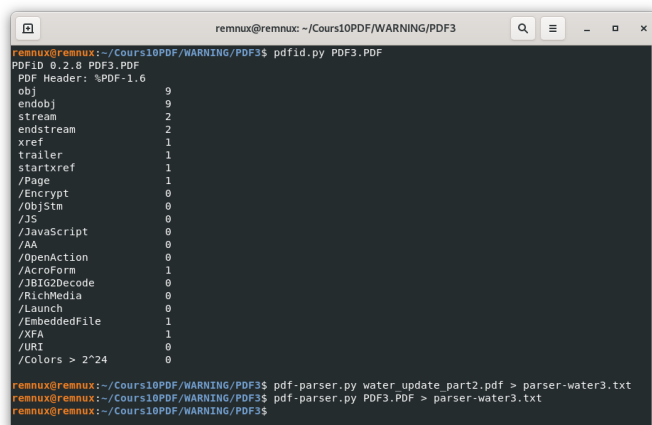
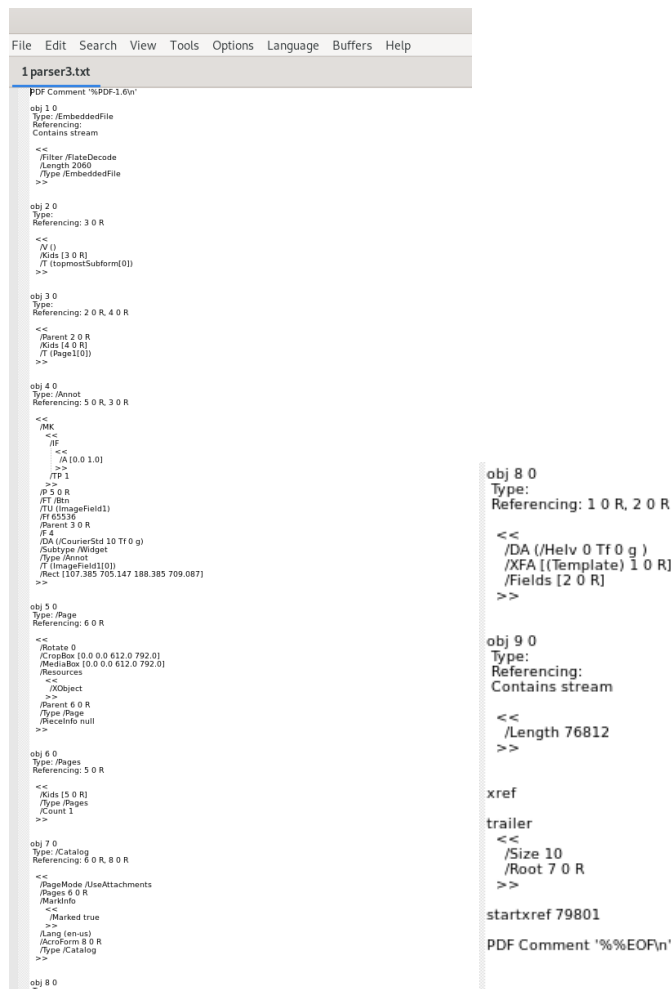
Exercice 1 – PDF malicieux & Analyse statique de maliciel (20p)

En utilisant les instructions du **laboratoire 1 - cours 10**, faites une analyse des PDF3 et PDF4, disponibles dans le laboratoire du cours 10

Commençons par le fichier PDF3 qui est *Research Paper on Nuclear Posture Review 2010.PDF* que j'ai renommé PDF3 pour que ce soit plus facile de le manier dans la ligne de commande. Même chose avec le pdf dans folder PDF4 je l'ai renommé PDF4

Nous commençons avec PDF3, et nous runnons la commande dans le lab pdf parser





C'est ce qui complete l'analyse de base par rapport au lab puisqu'il n'y a pas de code javascript. Nous pouvons aussi simplement utiliser *VirusTotal* pour les PDF qui semblent suspects.

beaucoup de caractère non lisible dans un mauvais format, possiblement du javascript, donc heureusement nous avons pdfid.py pour pouvoir voir s'il contient du javascript :

```
Activities  ScITE Text Editor  ▾

File Edit Search View Tools Options Language Buffers Help

1.parser4.txt

PDF Comment '%PDF-1.6%'

obj 387 0
Type:
Referencing:
<<
/Linearized 1
/L 374508
/O 395
/E 105533
/IN 5
/IT 366704
/H [ 1236 405]
>>

xref
trailer
<<
/Size 432
/Prev 366692
/Root 389 0 R
/Encrypt 388 0 R
/Info 61 0 R
/ID [ <531062B76A138B3DDC1D1C601E8D8CE5><95A231D8AC9A0046BAC9FE72D7E8644> ]
>>

startxref 0
PDF Comment '%EOF\r\n'
obj 430 0
Type:
Referencing:
Contains stream
<<
/Length 311
/C 344
/Filter /FlateDecode
```

```
Activities  ScITE Text Editor  ▾  2018-10-31 16:51
File Edit Search View Tools Options Language Buffers Help

1.parser4.txt

[REDACTED]
```

Et effectivement, nous avons du javascript dans celui-ci :

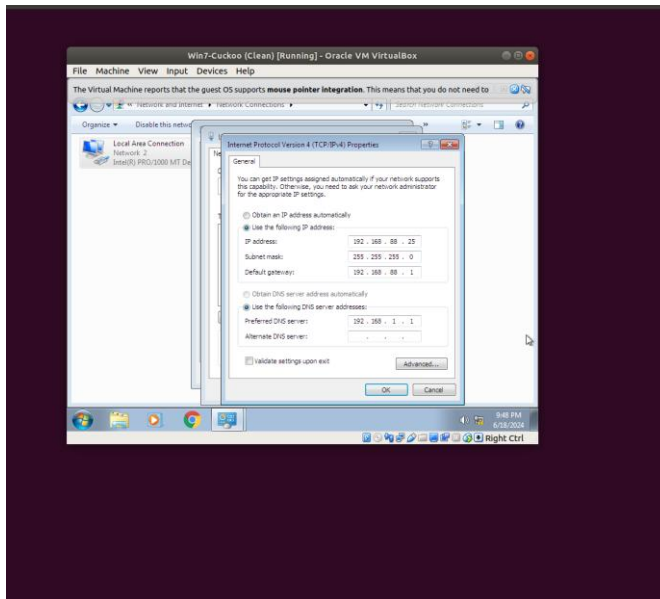


Exercice 2 – Analyse de maliciel dans une Sandbox (Cuckoo)

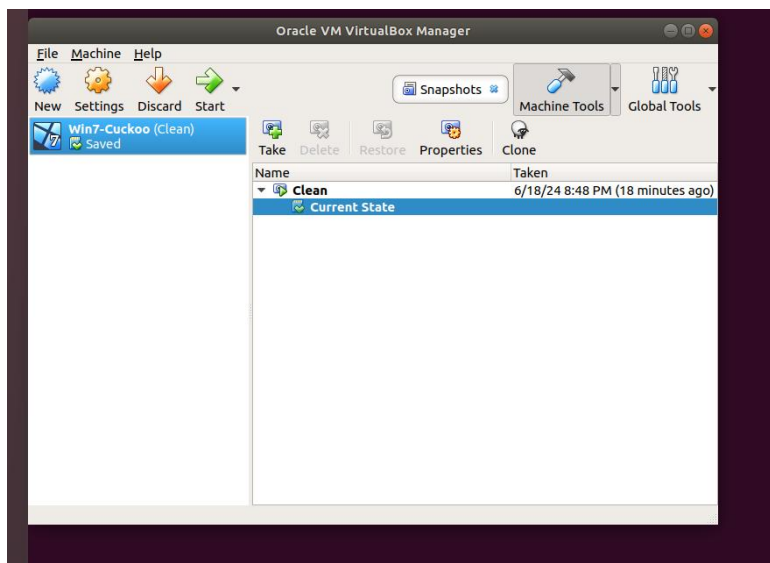
En utilisant les **laboratoire du cours 10 (Cuckoo lab)** :

- a) Créez un Sandbox Cuckoo (15p)

Nous commençons par changer les adresses IP de notre VM Win7-Cuckoo à ceux indiqués dans le lab.



On fait ensuite un snapshot qu'on intitule Clean



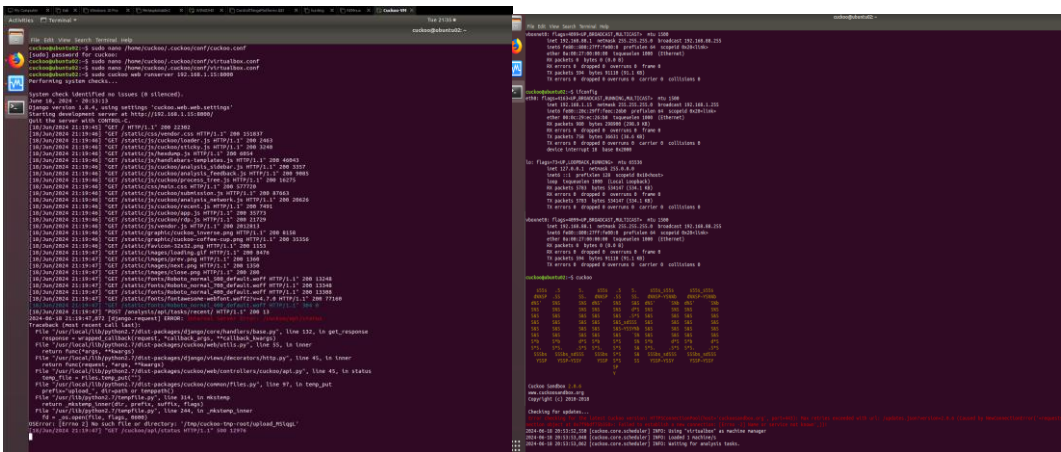
On modifie nos fichiers virtualbox.conf et cuckoo.conf


```
cuckoo@ubuntu02: ~  
File Edit View Search Terminal Help  
GNU nano 2.9.3 /home/cuckoo/.cuckoo/conf/cuckoo.conf Modified  
  
# Cuckoo is capable of sending "developer feedback" to the developers so that  
# they can more easily improve the project. This functionality also allows the  
# user to quickly request new features, report bugs, and get in touch with  
# support in general, etc.  
enabled = no  
name =  
company =  
email =  
  
[resultserver]  
# The Result Server is used to receive in real time the behavioral logs  
# produced by the analyzer.  
# Specify the IP address of the host. The analysis machines should be able  
# to contact the host through such address, so make sure it's valid.  
# NOTE: if you set resultserver IP to 0.0.0.0 you have to set the option  
# 'resultserver ip' for all your virtual machines in machinery configuration.  
ip = 192.168.88.1  
  
# Specify a port number to bind the result server on.
```

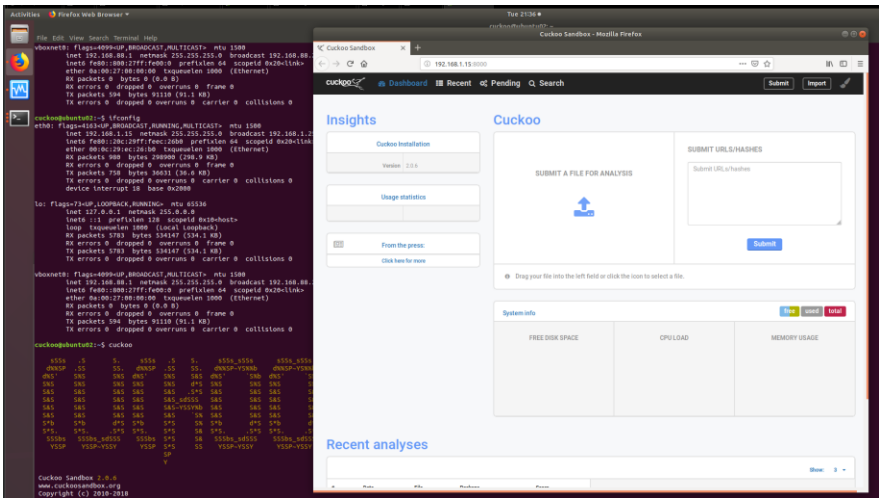
```
[remotecontrol]  
# Enable for remote control  
enabled = yes
```

```
cuckoo@ubuntu02: ~  
File Edit View Search Terminal Help  
GNU nano 2.9.3 /home/cuckoo/.cuckoo/conf/virtualmachines/cuckoo1.conf  
  
# Virtualbox will bind the VRDP interface to the first  
# controlport = 5000-5050  
  
[cuckoo1]  
# Specify the label name of the current machine as specified in  
# VirtualBox configuration.  
label = Win7-Cuckoo  
  
# Specify the operating system platform used by current machine.  
# [windows/darwin/linux].  
platform = windows  
  
# Specify the IP address of the current virtual machine.  
# IP address is valid and that the host machine is able to reach  
# the analysis will fail.  
ip = 192.168.88.25  
  
# (Optional) Specify the snapshot name to use. If you have multiple  
# snapshots, you can specify the one to use.
```

Après, on peut simplement entrer pour vérifier dans le browser si le sandbox a bel et bien fonctionné, même si nous sommes encore sous l'adresse statique 192.168.1.15

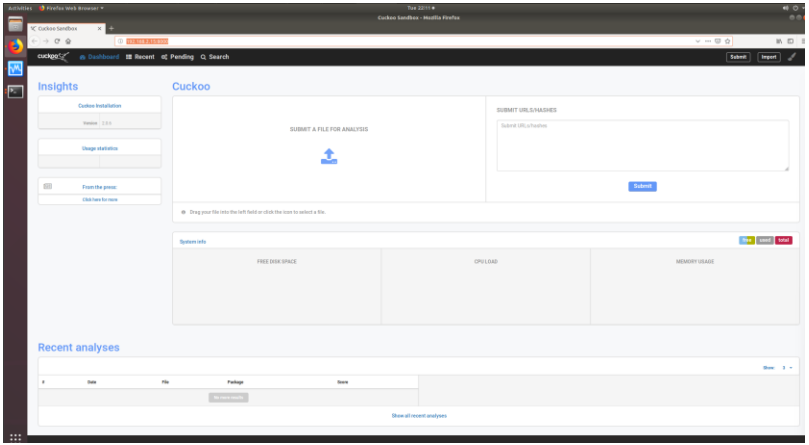


Maintenant, lorsqu'on va a 192.168.1.15:8000 dans notre browser, nous sommes prompté à l'interface web de cuckoo sandbox. Voir image ci-dessous



Maintenant, on doit simplement faire sûr qu'on peut communiquer avec mes autres VM pour qu'elles puissent accéder ce même interface. Pour cela, on doit changer notre adresse static dans /etc/network/interfaces.

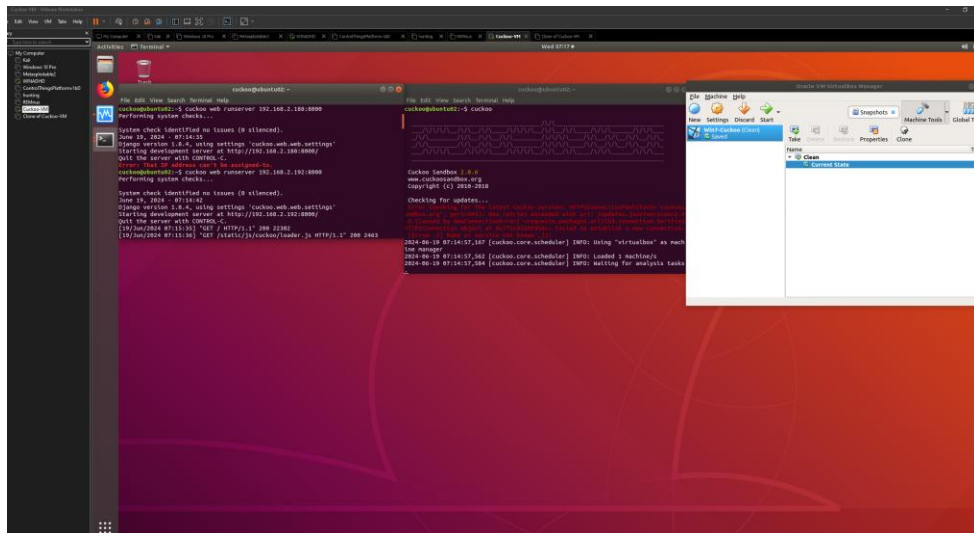
Voici le nouvel interface lorsque j'ai changé mon adresse IP a 192.168.2.15



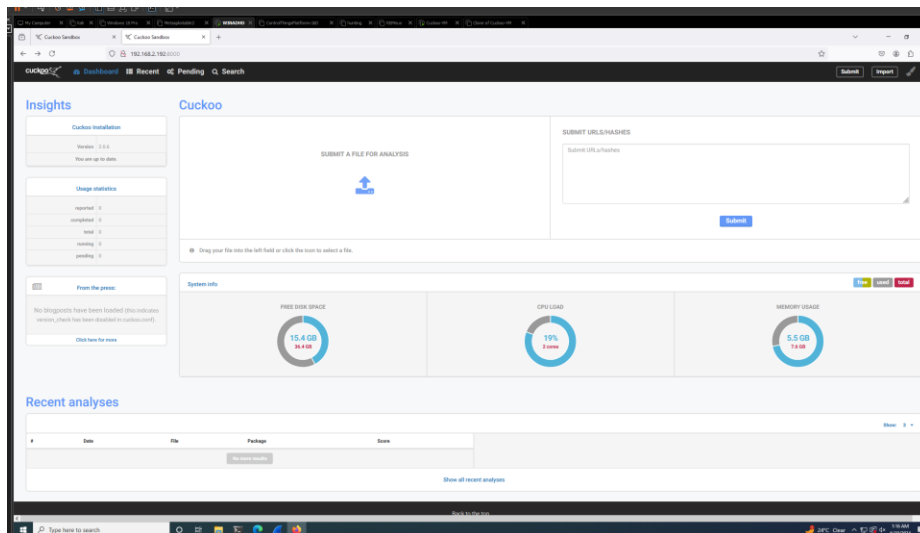
Maintenant, il suffit simplement d'aller dans la vm ADHD et accéder à l'interface web de cuckoo depuis notre serveur qu'on a créé dans la Cuckoo-VM.

Had to use a previous snapshot of my VM hence the new IP address

Voici mon terminal cuckoo qui relance le sandbox avec la nouvelle adresse IP, ainsi qu'une autre photo de ma WINADHD dans ma sandbox à partir du internet browser :



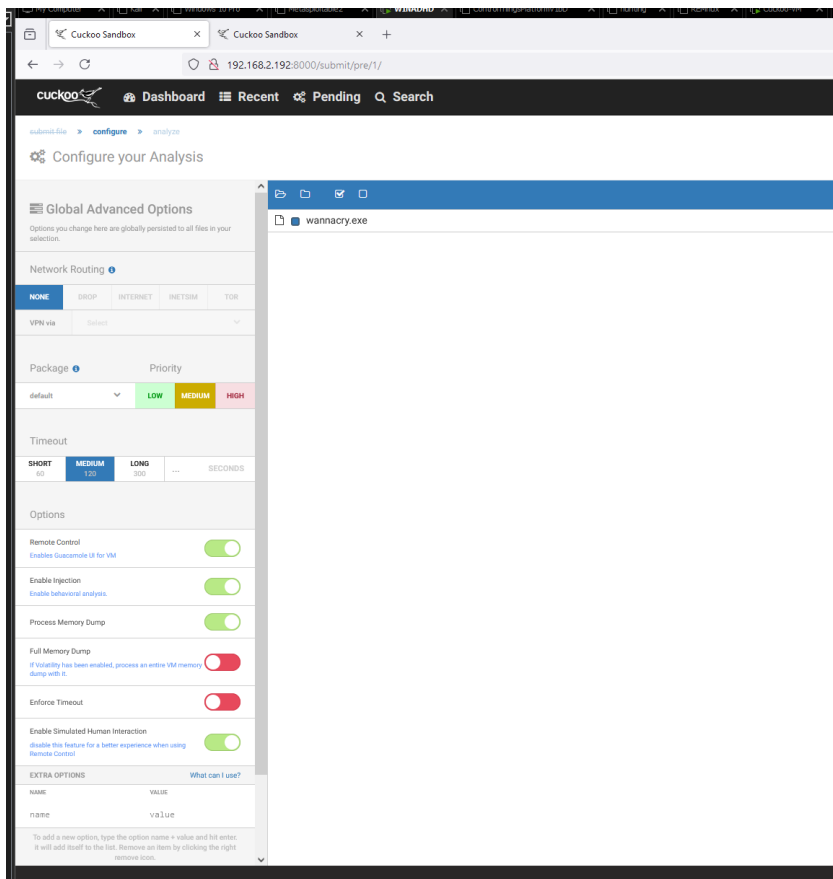
Et la WINADHD dans l'interface web :



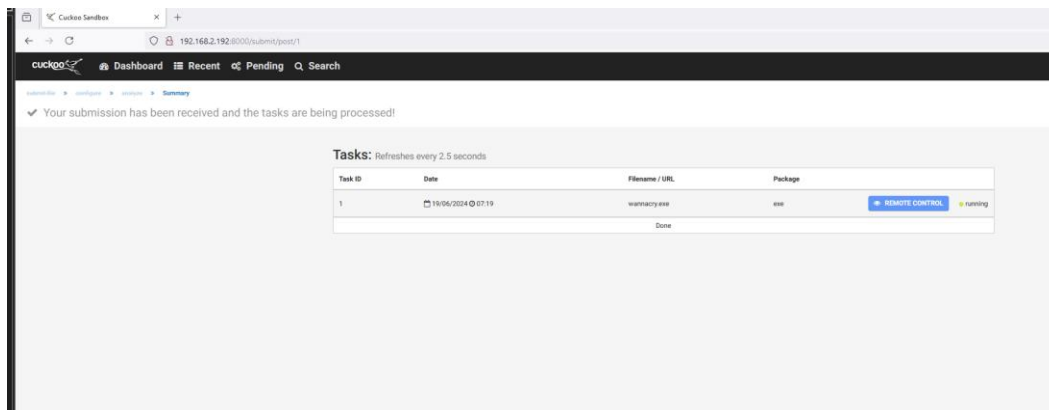
b) Similaire à l'exercice du laboratoire, analysez le malware wannacry.exe (5p)

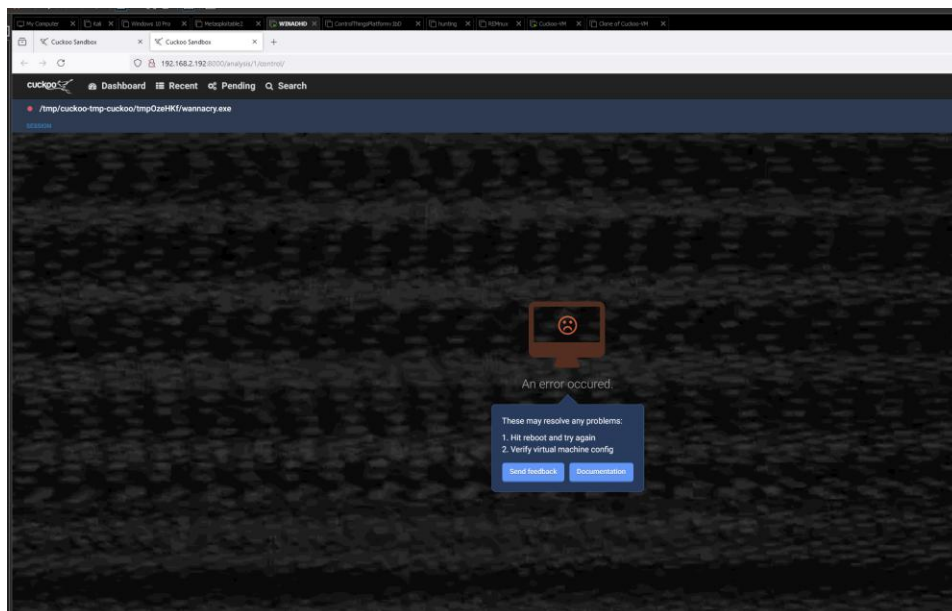
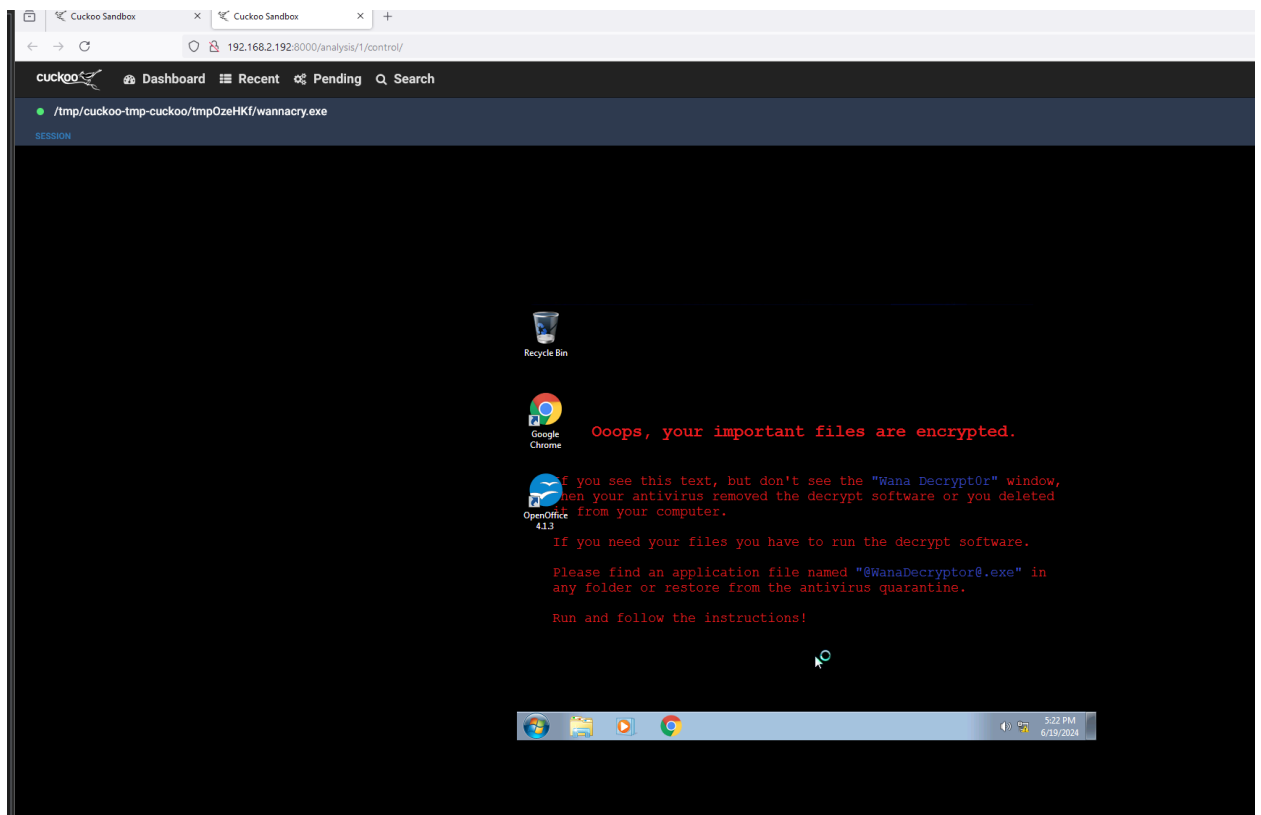
On load le fichier wannacry.exe dans la boite à sable. On coche le remote control.

Voici le resultat initial :

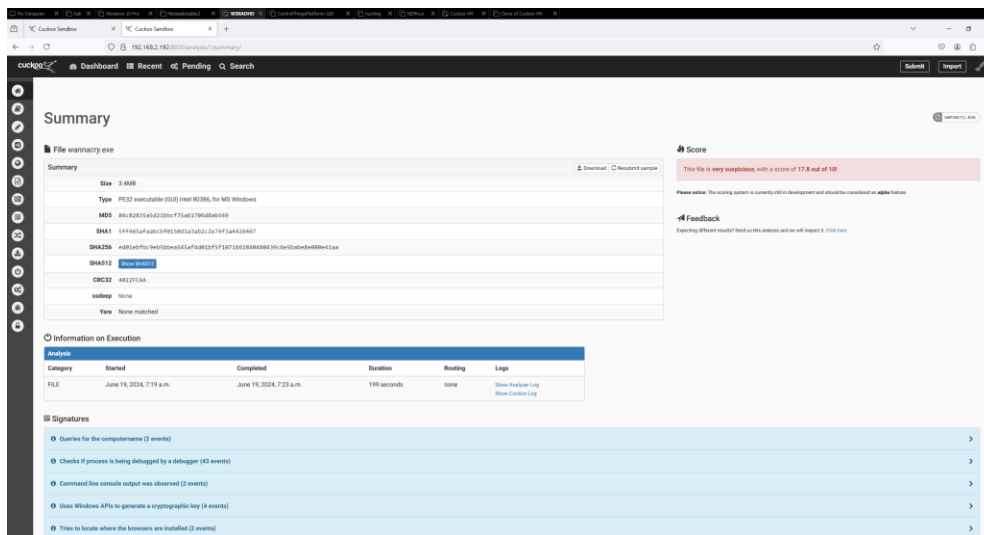


On clique sur remote control et on va etre prompt dans le simulateur avec le virus



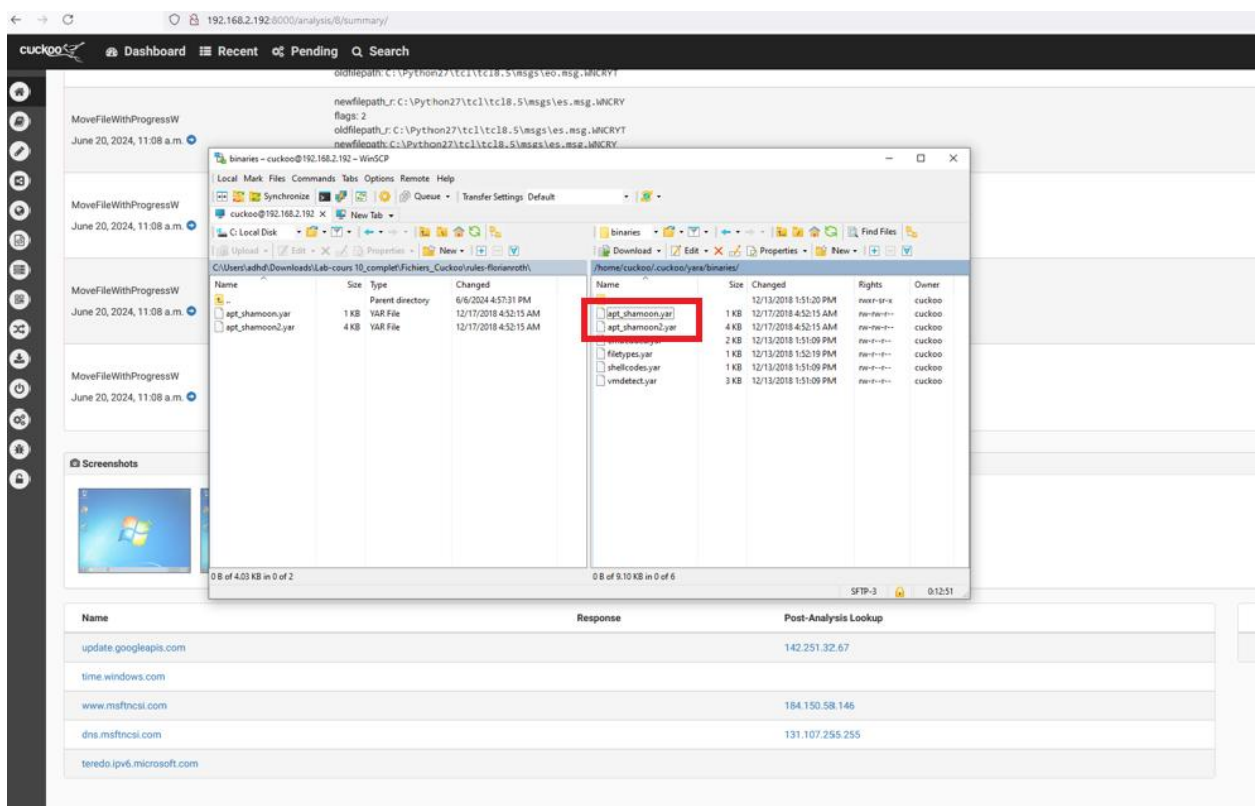


On fait "Show Report" et voici ce qu'on obtient :



c) Similaire à l'exercice du laboratoire, analysez le malware Shamoon, incluant la règle Yara (5p)

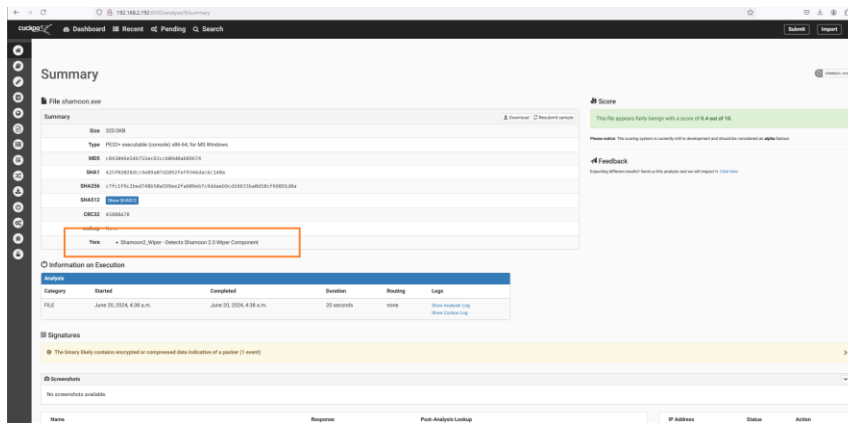
On commence par télécharger WinSCP, et on se connecte remotely à droite avec notre compte et IP de notre VM cuckoo. Par la suite, on transfère les fichiers dans notre répertoire de cuckoo comme indiqué dans le lab



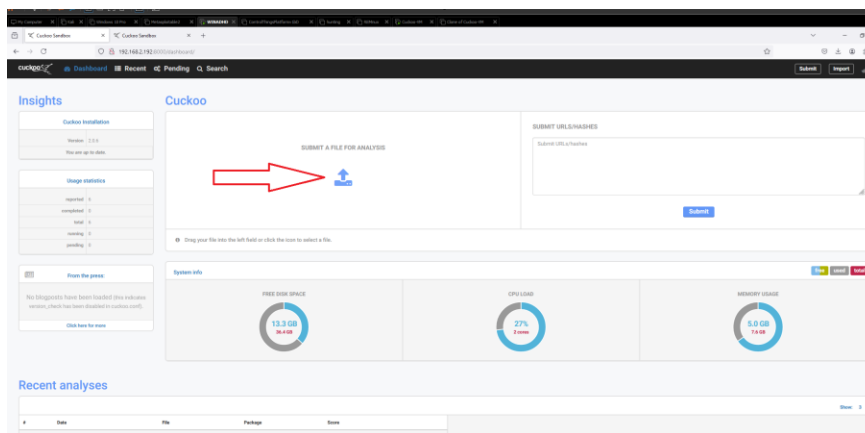
On redémarre par la suite notre serveur cuckoo qu'on a créé dans la VM-cuckoo.

Nous runnons à nouveau le malware, et nous pouvons voir que le score est relativement low comparé à avant.

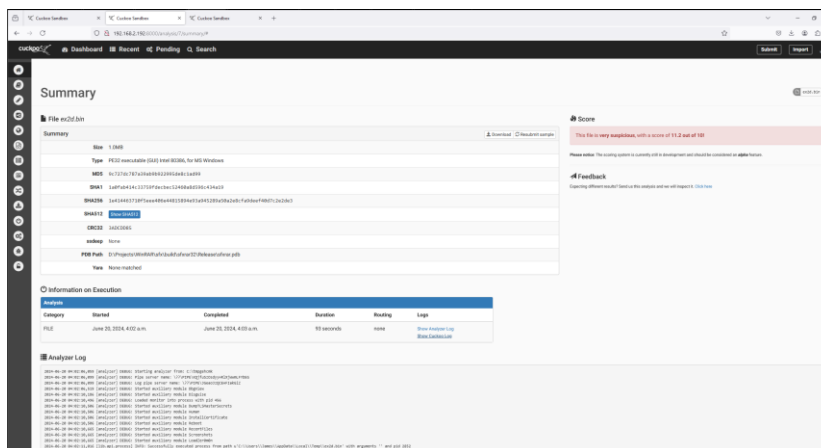
Pourquoi? Parce qu'avec cette règle, ce n'est pas suitable for proper sandbox operations. Mais, nous pouvons quand même voir dans le summary view que Yara a fait un hit. *Voir image ci-dessous.*



d) Analysez dans Cuckoo sandbox le fichier 2d.bin. Documentez vos trouvailles. (5p)

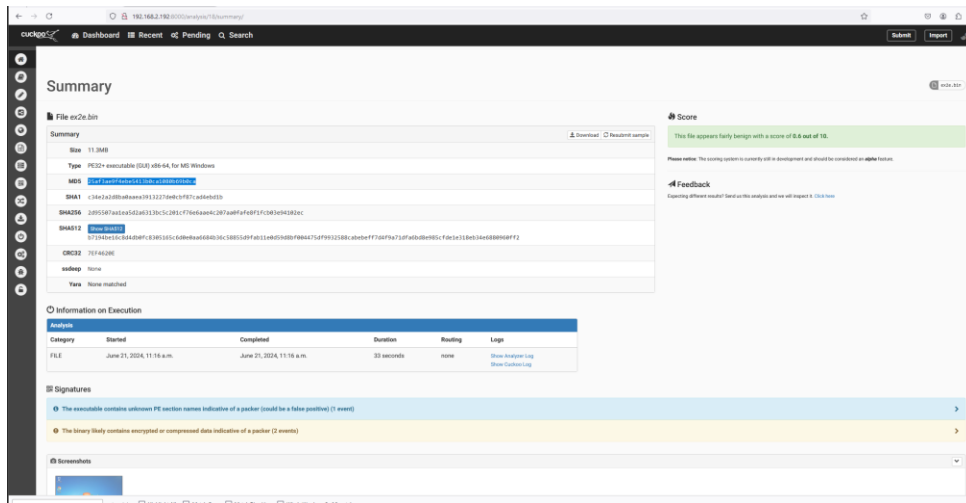


On upload le fichier ex2d.bin, on attend environ 1 minute et on a les résultats. Voici ce que nous avons.

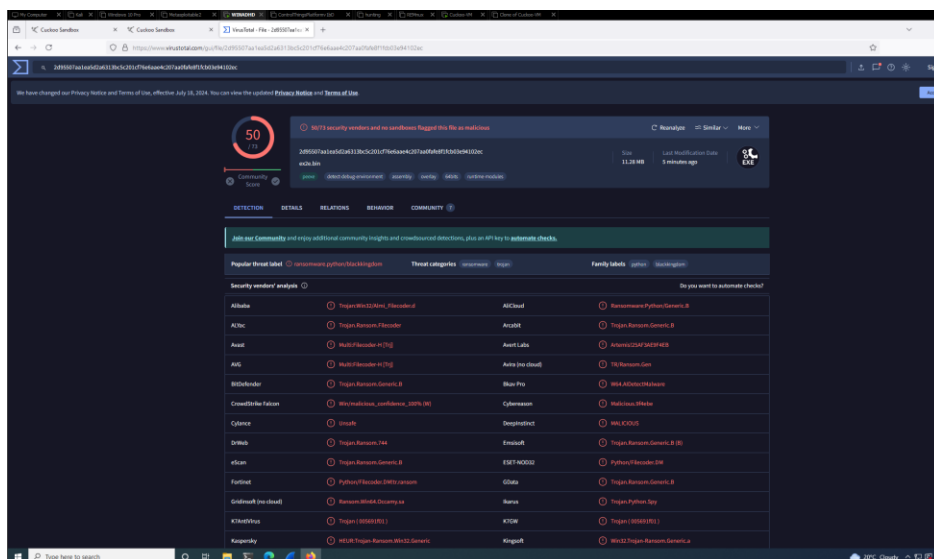
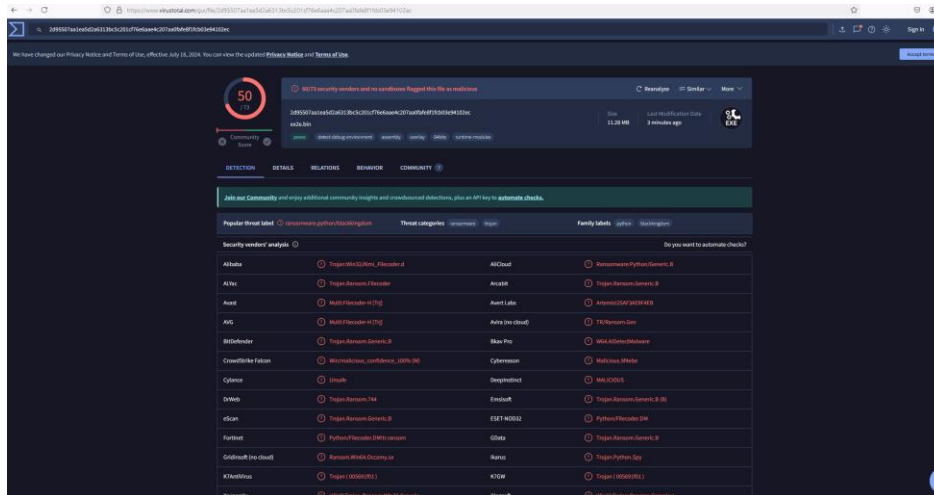


En cherchant les liens virustotal et github qui nous sont fournis, on peut dédier très rapidement que c'est un Trojan appelé LokiBot qui est un malware Trojan/ransomware.

- e) Analysez dans Cuckoo sandbox le fichier 2e.bin. Documentez vos trouvailles. Quel est le message affiche dans Windows 7, vu via remote control, pendant que le virus est exécuté? (5p)

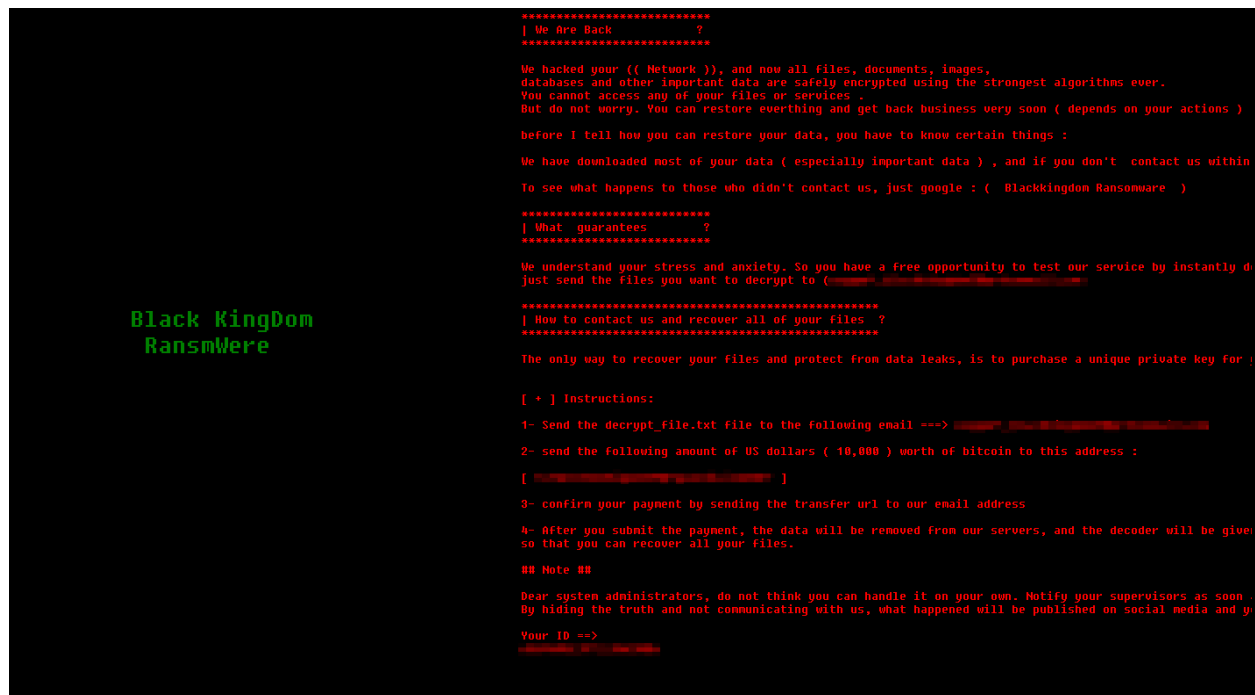


Avec les 2 règles ajoutées de Yara pour shamoon, et les defaults rules, nous n'avons pas vraiment rien capté dans le sommaire avec ex2e.bin, mais nous avons tous les hash, et nous pouvons analyser ceux-ci par exemple. *Voir image ci-dessous*



Nous pouvons voir que c'est un ransomware trojan nommé BlackKingdom

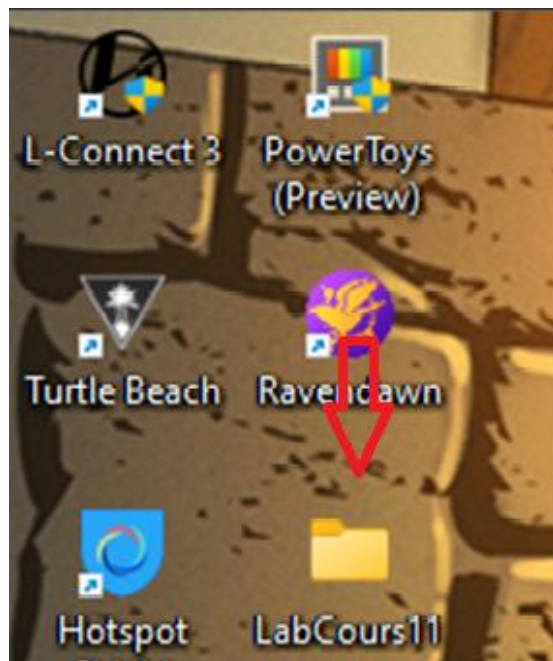
Et voici le message prompted par le virus ransomware Black Kingdom.



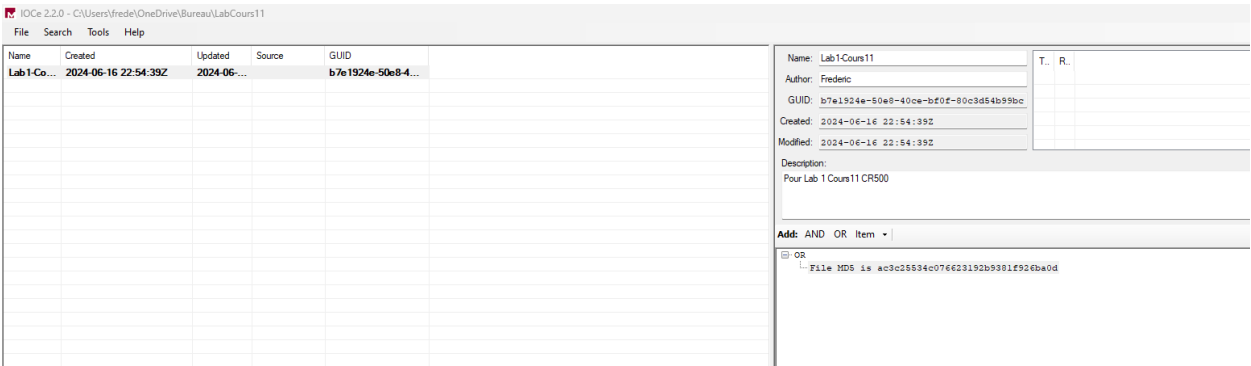
Exercice 3 – Threat Detection avec IOC & règles YARA

Effectuez et documentez les **laboratoires du cours 11**

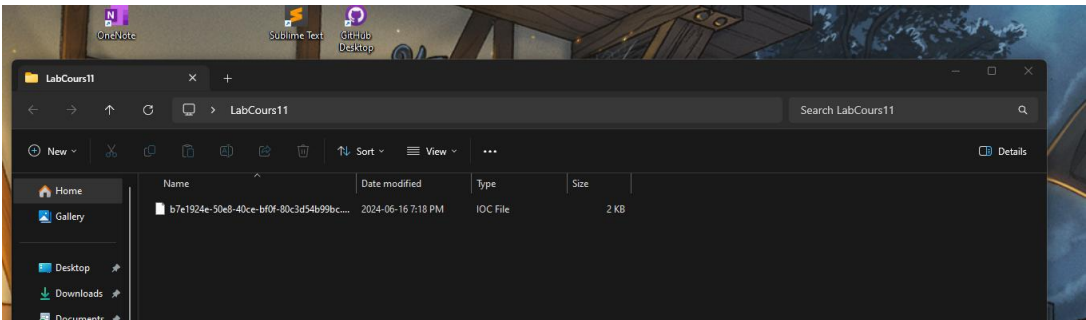
Nous commençons avec le lab 1 (Les IOC en action) et ensuite créer un fichier Cours11Lab sur notre Desktop



Nous faisons maintenant comme dans le lab 1 – cours 11 et nous ouvrons IOCe Mandiant, nous créons un nouvel indicateur et nous remplissons les métadonnées pour le IOC. Comme dans le lab.



Ensuite nous entrons les processus .exe et nous avons ensuite notre fichier dans le folder que nous avons créé LabCours11.

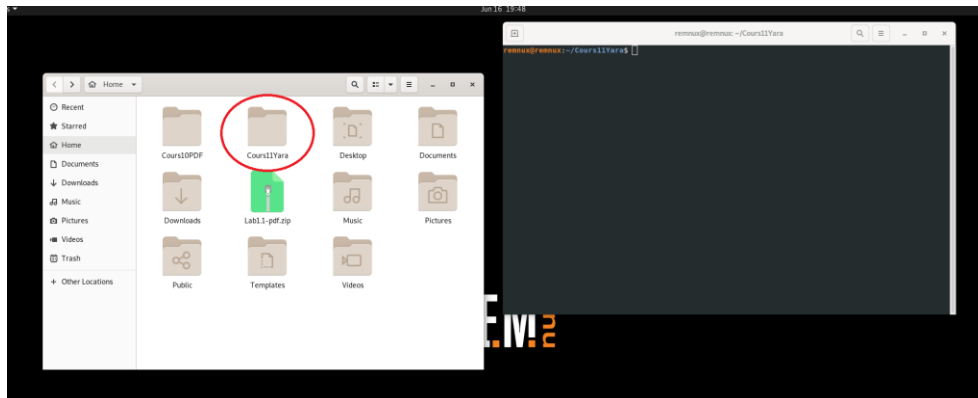


On commence après à faire "IOC Reports" et new. Et on choisit le fichier dans le desktop.

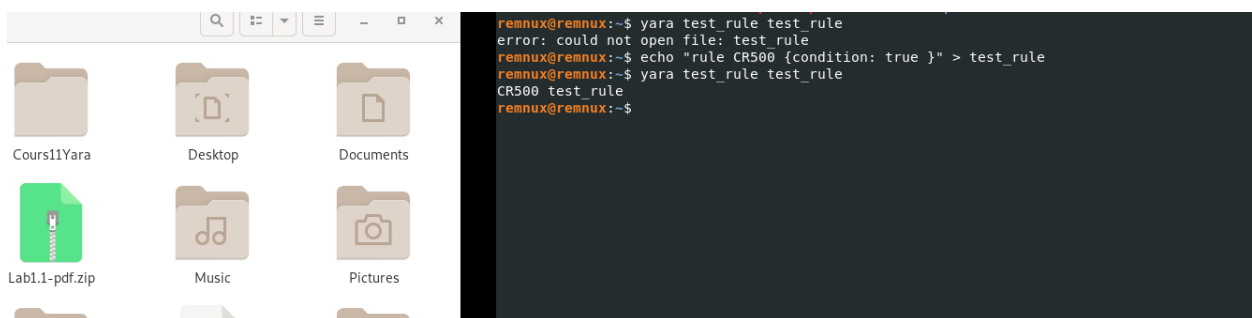
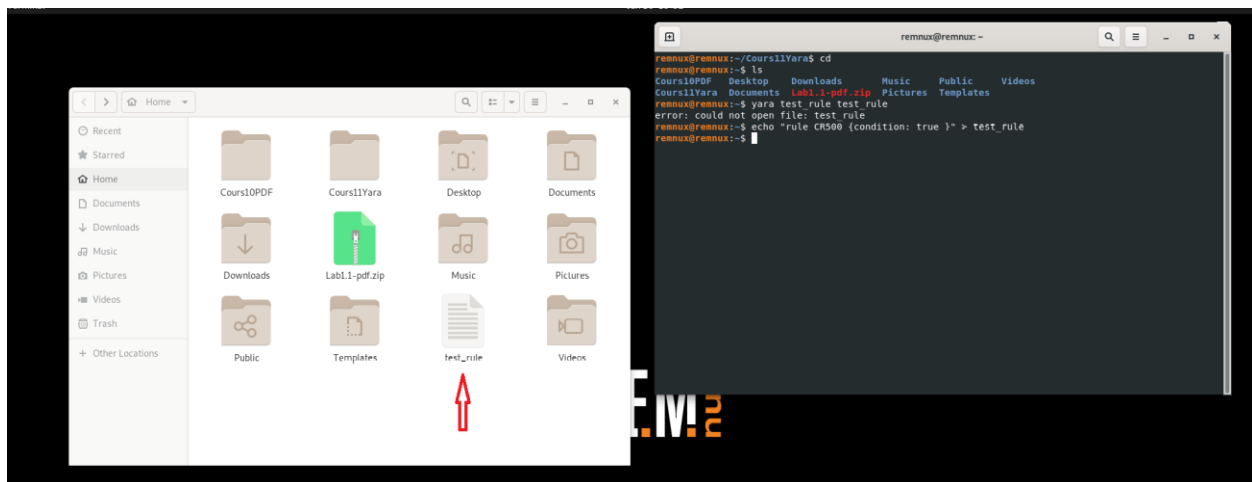
problèmes. La transmission de ce type de retour d'informations au personnel chargé de la manipulation des menaces et de l'environnement ainsi qu'au personnel chargé de la consommation des renseignements sur les menaces pourrait générer de meilleurs IOC et leur permettre de comprendre ce qui fonctionne, ce qui est nécessaire et quelles informations d'accompagnement pourraient aider les intervenants en cas d'incident.

Maintenant, Laboratoire 2 – Yara

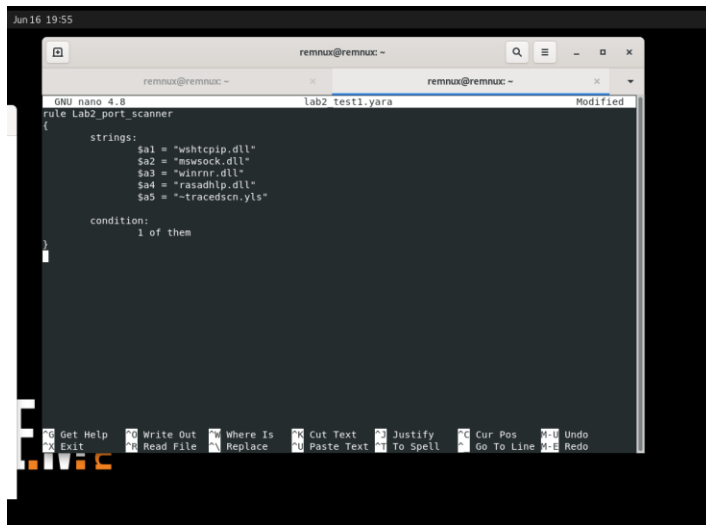
On commence par unzip le fichier Cours11Yara. Pour que nous ayons un simple fichier Cours11Yara avec les 2 fichiers memdumps à l'intérieur.



On exécute la commande **echo "rule CR500 {condition: true }" > test_rule** et on teste la règle par rapport à elle-même avec **yara test_rule test_rule**



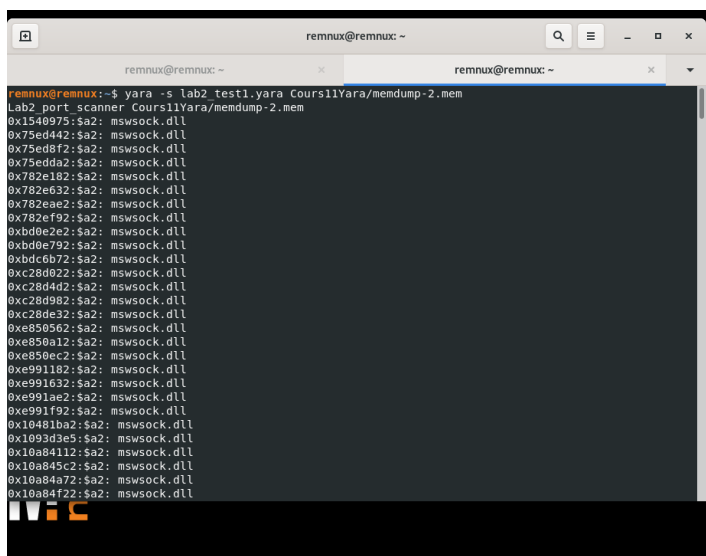
On insère maintenant les indicateurs dans la règle YARA comme indiqué dans le lab. Voir image ci-dessous pour la règle dans le txt editor.



```
rule Lab2_port_scanner
{
  strings:
    $s1 = "wshtcpip.dll"
    $s2 = "mswsock.dll"
    $s3 = "winrn.dll"
    $s4 = "rasadhip.dll"
    $s5 = "-tracedscn.yls"

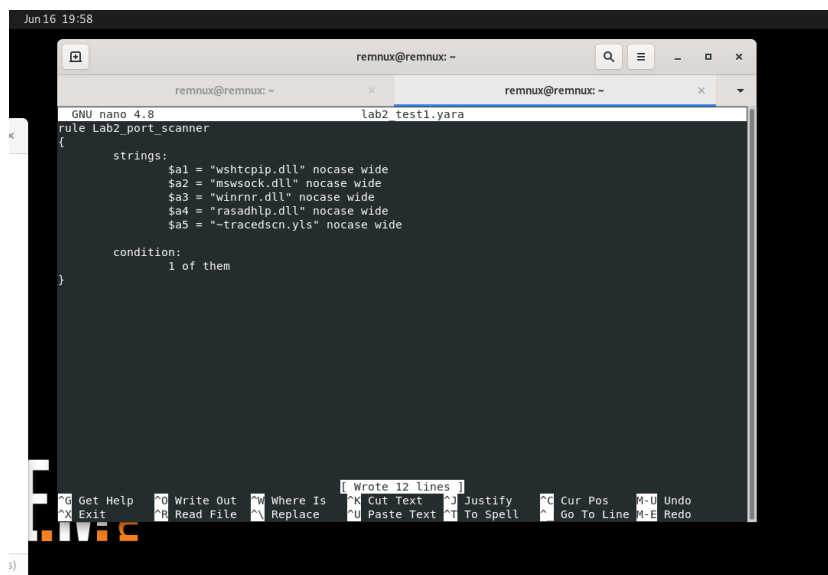
  condition:
    1 of them
}
```

On exécute la règle sur une des images mémoire.



```
remnux@remnux:~$ yara -s lab2_test1.yara Cours11Yara/mendump-2.mem
Lab2_port_scanner Cours11Yara/mendump-2.mem
0x1540975:$a2: mswsock.dll
0x75ed442:$a2: mswsock.dll
0x75ed4f2:$a2: mswsock.dll
0x75edda2:$a2: mswsock.dll
0x782e182:$a2: mswsock.dll
0x782e632:$a2: mswsock.dll
0x782eae2:$a2: mswsock.dll
0x782ef92:$a2: mswsock.dll
0xbd0e2e2:$a2: mswsock.dll
0xbd0e792:$a2: mswsock.dll
0xbdc6b72:$a2: mswsock.dll
0xc28d822:$a2: mswsock.dll
0xc28d4d2:$a2: mswsock.dll
0xc28d982:$a2: mswsock.dll
0xc28de32:$a2: mswsock.dll
0xe850502:$a2: mswsock.dll
0xe8509a2:$a2: mswsock.dll
0xe850ec2:$a2: mswsock.dll
0xe991182:$a2: mswsock.dll
0xe991632:$a2: mswsock.dll
0xe991ae2:$a2: mswsock.dll
0xe991f92:$a2: mswsock.dll
0x10481ba2:$a2: mswsock.dll
0x1093d3e5:$a2: mswsock.dll
0x10a84112:$a2: mswsock.dll
0x10a845c2:$a2: mswsock.dll
0x10a84a72:$a2: mswsock.dll
0x10a84f22:$a2: mswsock.dll
```

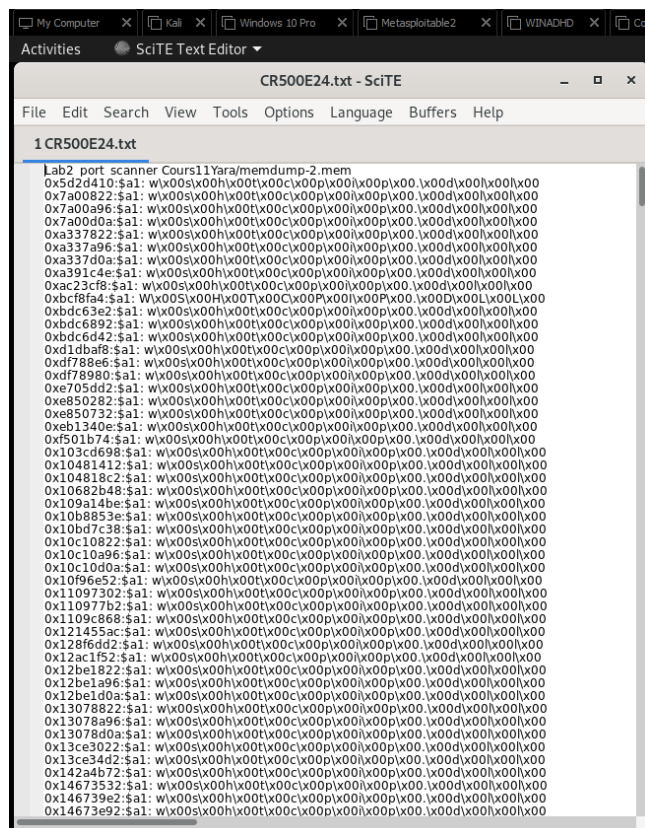
On ajoute ensuite "nocase" et "wide" après chaque chaîne comme ci-dessous :



On enregistre et on quitte l'éditeur avec **CTRL+O** et **CTRL+X**.

Cette fois, nous nous attendons à beaucoup plus de résultats, nous les afficherons donc dans un fichier texte pour une visualisation plus facile. Nous exécutons la commande suivante : **yara -s lab2_test1.yara Cours11Yara/memdump-2.mem > CR500E24.txt**

Nous sommes ensuite présentés avec ces résultats dans le fichier texte :

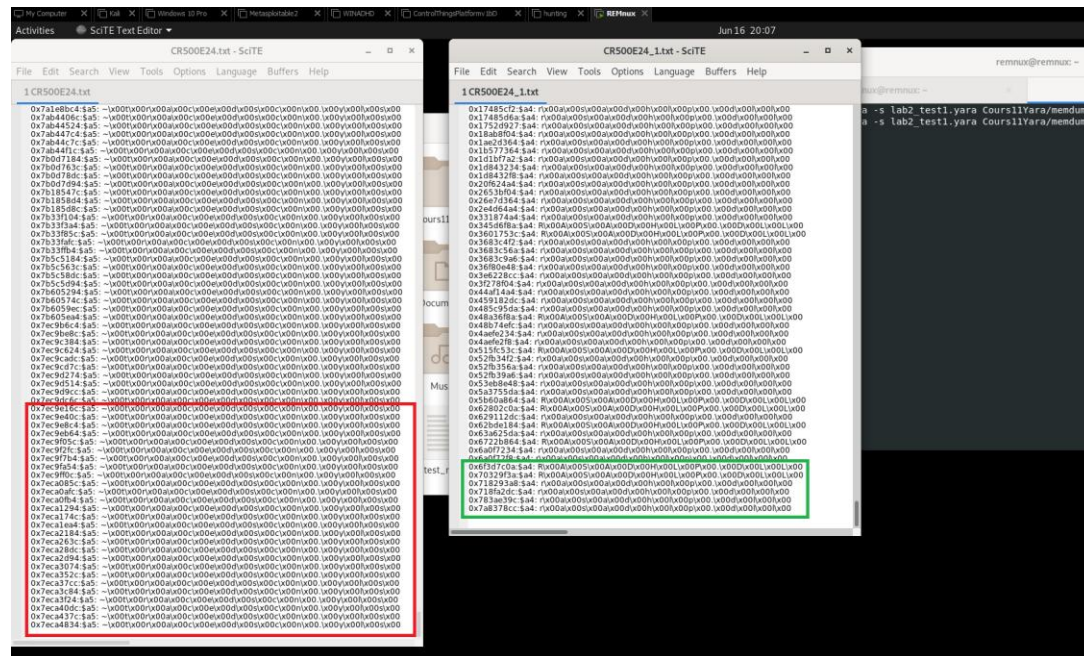


Nous avons désormais des hits sur chaque chaîne. Les résultats sont en HEX à cause de l'option "wide" puisqu'il ne s'agit plus de simples chaînes ASCII observables. Mais les deux options "wide" et "nocase" ont toutes deux permis de trouver des instances de chaînes que vous n'auriez pas vues autrement.

Il est important de valider la règle YARA par rapport à une bonne image connue pour supprimer toutes les chaînes fortement faussement positives dans le IOC.

On exécute la règle lab2_test1.yara sur l'image mémoire de base avec la commande suivante :
yara -s lab2_test1.yara Cours11Yara/memdump-1.mem > CR500E24_1.txt

Nous avons maintenant nos 2 fichiers que l'on peut comparer, comme dans le lab nous avons les même résultats



Si on souhaite plus d'informations pour rédiger des règles plus complexes, on peut consulter la documentation YARA à l'adresse :

<https://yara.readthedocs.io/en/stable/writingrules.html>

Exercice 4 – Analyse forensique avec Redline (25p)

En utilisant la capture Redline suivante

<https://drive.google.com/file/d/1HZRBXRlxqSUiVojKeyhDir5C499NwPAF/view?usp=sharing> (mot de passe infected) répondez aux question suivantes (similaire au lab cours 9)

- a) Quel est le nom, système d'opération, logged on user et l'adresse IP du système victime (5p)

Nom: **WIN7X64**

Machine Name:	WIN7X64
Host Name:	Win7x64
System Date:	2023-06-17 16:54:24Z
Time Zone DST:	Eastern Daylight Time
Time Zone Standard:	Eastern Standard Time
Process ID:	144 (C:\Windows\System32\cmd.exe)

OS: Windows 7 Professional 7600

Operating System Information	
Operating System:	Windows 7 Professional 7600
Product Name:	Windows 7 Professional

logged on user: Win7x64\Lucian,WORKGROUP\WIN7X64\$

Logged on User:	Win7x64\Lucian,WORKGROUP\WIN7X64\$
BIOS Information	

Adresse IP: 192.168.1.208

System Information	
Operating System:	Windows 7 Professional 7600
Domain:	WORKGROUP
Host:	Win7x64
Primary IP Address:	192.168.1.208

- b) Pendant le réponse aux incidents vous identifiez une machine avec l'adresse IP 192.168.1.105.
- a. En regardant les services, ports ... ouverts, pourriez-vous identifier une connexion et, si le cas, si cela est suspecte? (5p)

Oui nous pouvons observer une connexion depuis un serveur http 8000 (basic http server).

Évidemment, un trojan.exe est extrêmement suspecte et devrait être investigué/intervenir.

	trojan.exe	864	C:\Users\Lucian\Downloads\trojan.exe	ESTABLISHED	192.168.1.208	49343	192.168.1.105	4444	TCP
---	------------	-----	--------------------------------------	-------------	---------------	-------	---------------	------	-----

	Download Type	Source URL	Target Directory	File Name	File Size	Bytes Downloaded	State	Start Date	End Date	Last Accessed
	Manual	http://192.168.1.105:8000/trojan	C:\Users\Lucian\Downloads	trojan	7 Kilobytes	7 Kilobytes	Finished	2023-06-17 16:37:48Z	2023-06-17 16:37:49Z	

- b. Pourriez-vous identifier la provenance du fichier qui communique avec cette machine? (5p)

C'est un exécutable dans le fichiers Downloads. Donc le fichier a été téléchargé et puis exécuté à distance. Depuis l'adresse et source URL 192.168.1.105:8000/trojan

Download Type	Source URL	Target Directory	File Name	File Size	Bytes Downloaded	State	Start Date	End Date	Last Accessed
Manual	http://192.168.1.105:8000/trojan	C:\Users\Lucian\Downloads	trojan	7 Kilobytes	7 Kilobytes	Finished	2023-06-17 16:37:48Z	2023-06-17 16:37:49Z	

- c) Il y a une connexion du qModMaster vers une autre machine. Pourriez-vous identifier :
- a. Le nom et l'id du processus (2.5p)

qModMaster.exe / PID : 3880

qModMaster.exe	3880	C:\Users\Lucian\Desktop\qModMaster	ESTABLISHED	192.168.1.208	49588	192.168.1.44	1502	TCP
----------------	------	------------------------------------	-------------	---------------	-------	--------------	------	-----

- b. La date du lancement (5p)

2023-06-17

URL	file:///C:/Users/Lucian/Desktop/qModMaster-Win32-...	0	2023-06-17 16:42:12Z
IP	192.168.1.208	49588	192.168.1.44

c. L'ip et le port de destination (2.5p)

IP est 192.168.1.44 / Port de destination est 1502

qModMaster.exe	3880	C:\Users\Lucian\Desktop\qModMaster	ESTABLISHED	192.168.1.208	49588	192.168.1.44	1502	TCP
----------------	------	------------------------------------	-------------	---------------	-------	--------------	------	-----